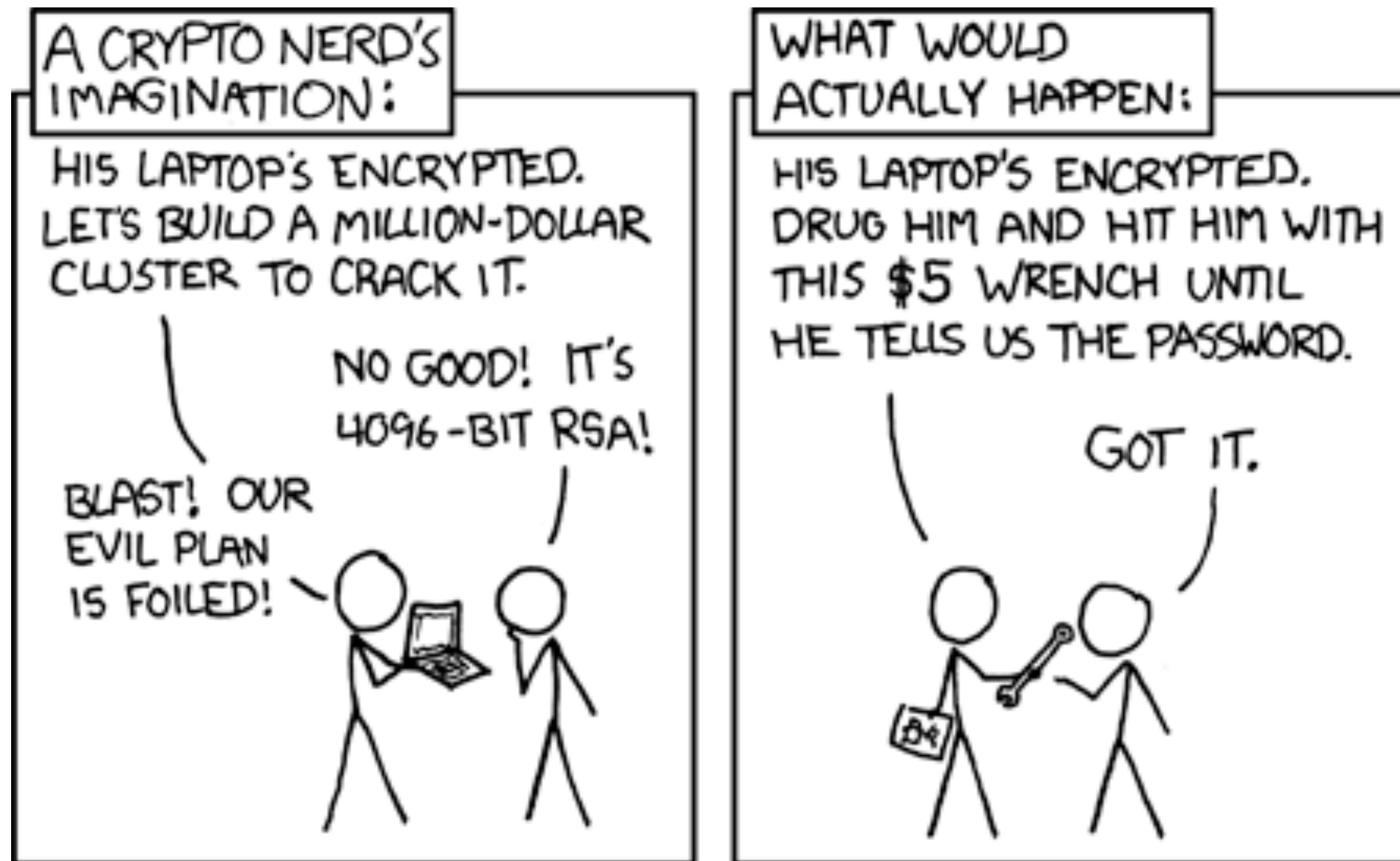


Cybersecurity Fundamentals



Randall Munroe
<https://xkcd.com/538/>

Learning Goals

- ▶ Get an understanding of what cybersecurity is
 - ▶ Definitions of cybersecurity
 - ▶ The difference between security and safety
 - ▶ Security goals and their role in cybersecurity
 - ▶ Assumptions and their role in cybersecurity
 - ▶ The cybersecurity kill chain and alternative frameworks
- ▶ Understand how to perform risk and threat analyses
 - ▶ The security mindset
 - ▶ Risk & threat analyses based on attack trees
 - ▶ The STRIDE classification of threats
 - ▶ Attacker motivations

Learning Goal 9D52F7

What is Cybersecurity?

Cybersecurity Definition by NIST

The process of protecting information by preventing, detecting, and responding to attacks.

- Cybersecurity Framework Version 1.1

Security vs Safety

► In Danish both “sikkerhed”, but there is an important difference

Security

The process of protecting information by preventing, detecting, and responding to attacks.

► Protection from **attacks**

Safety

Freedom from conditions that can cause death, injury, occupational illness, damage to or loss of equipment or property, or damage to the environment.

► Protection from **unintended errors**

Security vs Safety

- ▶ In Danish both “sikkerhed”, but there is an important difference

Security

- ▶ Protection from **attacks**



By USAA
<https://www.military.com/off-duty/autos/4-sensible-ways-to-help-avoid-car-theft.html>

Safety

- ▶ Protection from **unintended errors**

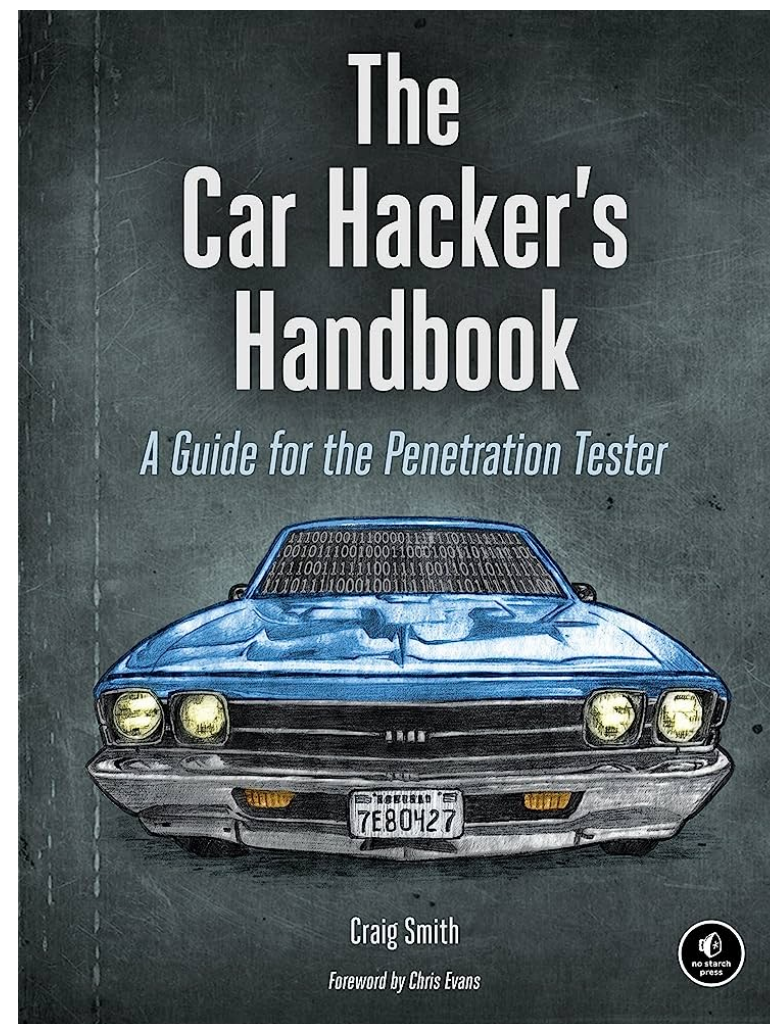


By Pineapple fez - Eigenes Werk,
CC BY-SA 3.0,
<https://commons.wikimedia.org/w/index.php?curid=11867784>

Security vs Safety

► In Danish both “sikkerhed”, but there is an important difference

Security



No Starch Press,
<https://nostarch.com/carhacking>

In a digitized world, security vulnerabilities can impact safety



Safety



By Pineapple fez - Eigenes Werk,
CC BY-SA 3.0,
<https://commons.wikimedia.org/w/index.php?curid=11867784>

Cybersecurity Definition by NIST

The process of protecting information by preventing, detecting, and responding to attacks.

- Cybersecurity Framework Version 1.1

Cybersecurity Definition by NIST

This definition is not quite precise enough, why?

Protecting in regards to what?

Really only information?

*The process of **protecting** **information** by preventing, detecting, and responding to attacks.*

- Cybersecurity Framework Version 1.1

Another Cybersecurity Definition by NIST



“All the things” → **Assets**

Prevention of damage to, protection of, and restoration of computers, electronic communications systems, electronic communications services, wire communication, and electronic communication, including information contained therein, to ensure its availability, integrity, authentication, confidentiality, and non-repudiation.

- CNSSI 4009-2015



Cybersecurity Protection Goals

Cybersecurity Protection Goals

- ▶ Originally only the C-I-A triad defined by NIST
 - ▶ **Confidentiality:** Ensuring that data or information is not made available or disclosed to unauthorized persons or processes.
 - ▶ **Integrity:** Guarding against improper information modification or destruction in an unauthorized and undetected manner.
 - ▶ **Availability:** Ensuring timely and reliable access to and use of information.

Cybersecurity Protection Goals

- ▶ Originally only the C-I-A triad defined by NIST
 - ▶ **Confidentiality:** Ensuring that data or information is not made available or disclosed to unauthorized persons or processes.
 - ▶ **Integrity:** Guarding against improper information modification or destruction in an unauthorized and undetected manner.
 - ▶ **Availability:** Ensuring timely and reliable access to and use of information.
- ▶ Two added by NIST later on
 - ▶ **Authenticity:** Verifying that a user, process, or device is the one claimed, often as a prerequisite to allowing access to resources in an information system.
 - ▶ **Non-repudiation:** Assurance the sender of data is provided with proof of delivery and the recipient is provided with proof of the sender's identity, so neither can later deny having processed the data.

Cybersecurity Protection Goals “in the real world”

► Confidentiality



By Tom Varco, CC BY-SA 3.0,
<https://commons.wikimedia.org/w/index.php?curid=1033836>

► Integrity



By Rebeca Mello, Getty Images,
<https://www.fitbook.de/gesundheit/lebensmittel-fast-alle-stoffe-in-plastikverpackungen-unbekannt>

► Availability



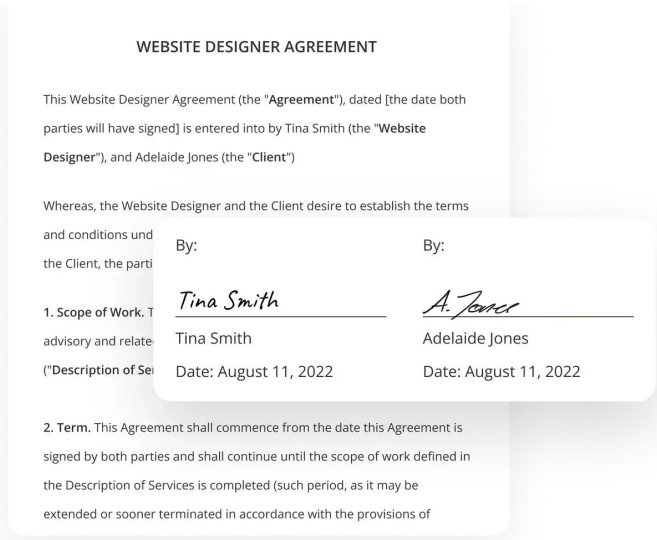
By Frank Homann, General Anzeiger,
https://ga.de/region/siebengebirge/koenigswinter/bauarbeiten-an-b42-beginnen-tunnel-zwischen-koenigswinter-und-bonn_aid-61954115

► Authenticity



By Schengen-Visa News,
<https://www.schengenvisa.info.com/news/denmark-wants-permanent-border-controls-to-stop-immigration-terrorism/>

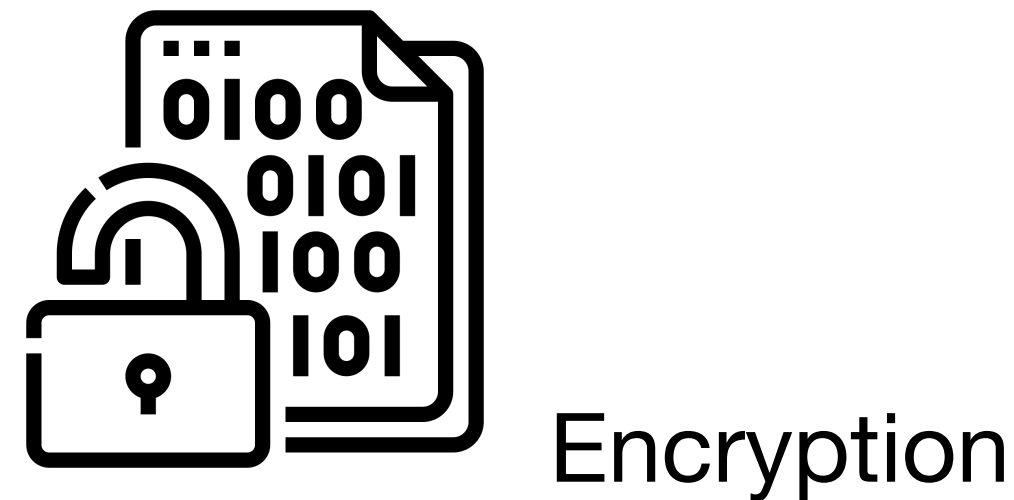
► Non-repudiation



By Indy,
<https://weareindy.com/tools/contracts>

Cybersecurity Protection Goals

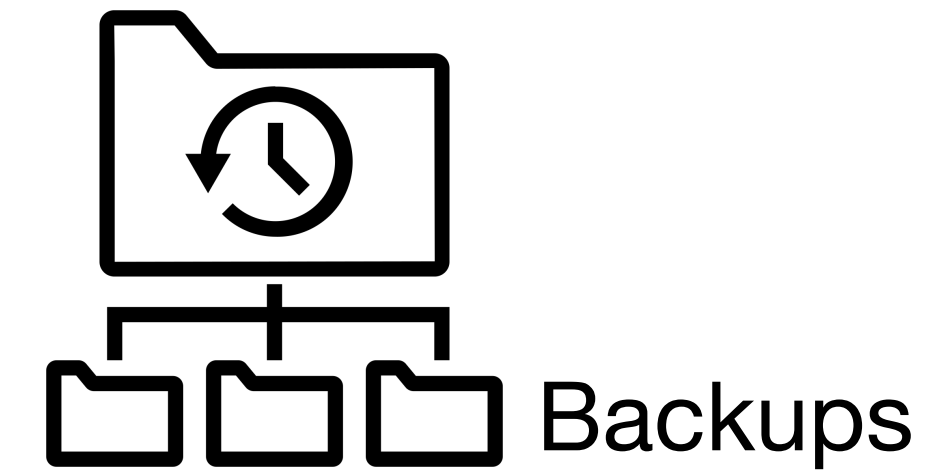
► Confidentiality



► Integrity



► Availability



► Authenticity



► Non-repudiation



Cybersecurity Protection Goals

- ▶ But there are even more, depends on the context
 - ▶ Privacy
 - ▶ Anonymity
 - ▶ ...
- ▶ They might contradict each other
 - ▶ Encrypting data might increase confidentiality, but decreases availability
 - ▶ Non-repudiation or authenticity might contradict anonymity
 - ▶ ...
- ▶ Choice of security goals depends on **Assumptions** about the environment, actors, etc.

Assumptions

► Confidentiality



- Thieves will not carry it away
- No duplicate keys
- ...

By Tom Varco, CC BY-SA 3.0,
<https://commons.wikimedia.org/w/index.php?curid=1033836>

► Integrity



By Rebeca Mello, Getty Images,
<https://www.fitbook.de/gesundheit/lebensmittel-fast-alle-stoffe-in-plastikverpackungen-unbekannt>

► Authenticity



By Schengen-Visa News,
<https://www.schengenvisa.info.com/news/denmark-wants-permanent-border-controls-to-stop-immigration-terrorism/>

► Non-repudiation



By iStock.com/SDI Productions,
<https://www.computerbild.de/artikel/cb-News-Internet-Mit-automatischem-Brief-Die-Deutsche-Post-vereinfacht-das-Einschreiben-33863007.html>

► Availability



By Frank Homann, General Anzeiger,
https://ga.de/region/siebengebirge/koenigswinter/bauarbeiten-an-b42-beginnen-tunnel-zwischen-koenigswinter-und-bonn_aid-61954115

Can you think of other assumptions?

Assumptions

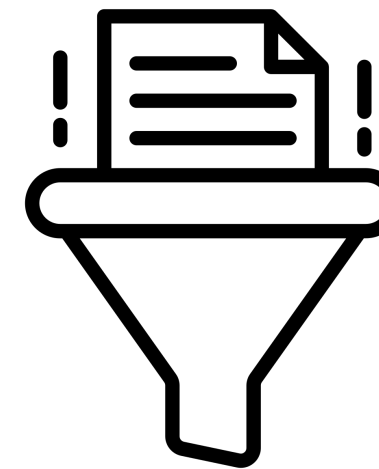
► Confidentiality



- **Attacker is computationally bound**
- **Algorithms are not broken**
- ...

Encryption

► Integrity



- **Algorithms are not broken**
- ...

Cryptographic Hashes

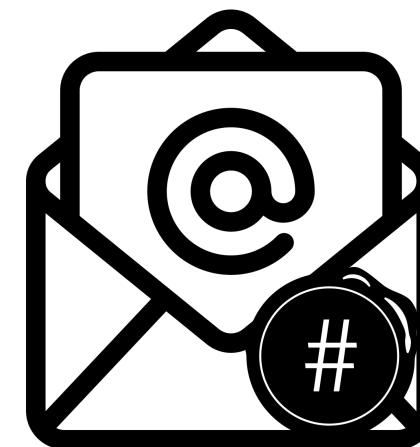
► Authenticity



Message Authentication Codes

- **Key has not been shared with third-parties**
- **Algorithms are not broken**
- ...

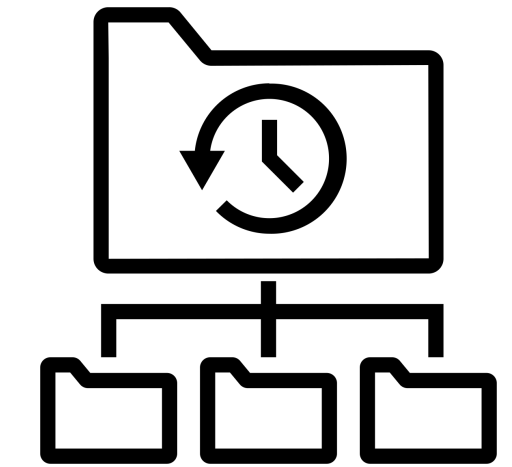
► Non-repudiation



Digital Signatures with Received Receipt

- **Private key has not leaked**
- **Algorithms are not broken**
- ...

► Availability



Backups

- **Backups are not destroyed as well**
- **All relevant data is in backup**
- ...

Assumptions

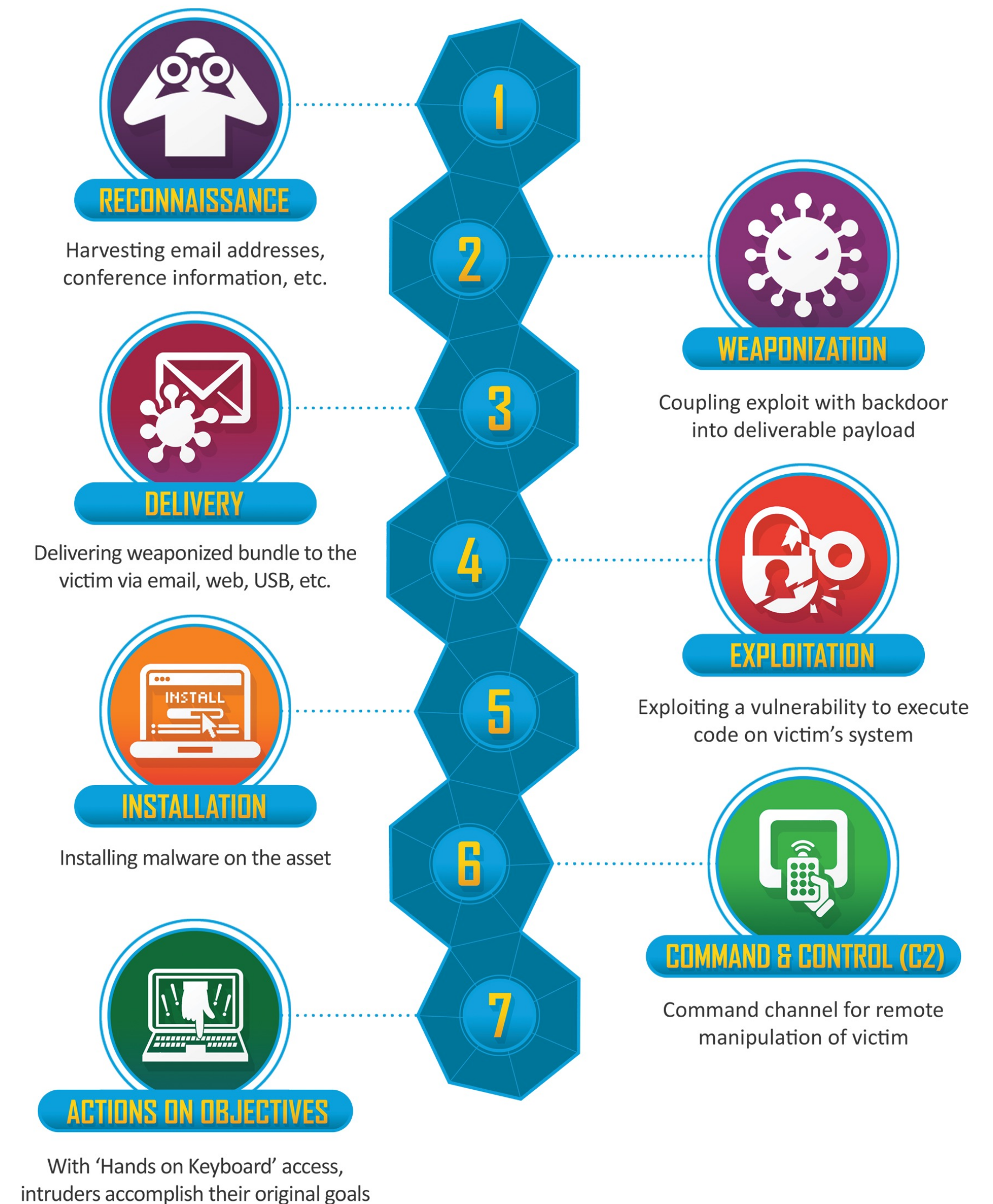
- ▶ Cybersecurity needs context
 - ▶ Security only ever holds under specified assumptions
 - ▶ If unsure ask about the assumptions made!
- ▶ No system that is sufficiently complex to be practically useful is 100% secure
 - ▶ There are always bugs in the code
 - ▶ Side-channels to get secret info
 - ▶ ...
- ▶ Attackers strike wherever insufficient protection goals or unmet assumptions allow it
- ▶ They use these weak spots to build a so-called Cyber Kill Chain

Cyber Kill Chain

- ▶ First introduced by Lockheed Martin
- ▶ Describes the most typical stages of most cyber attacks
- ▶ 7 stages from information gathering to achieving actual goal
- ▶ Widely used in practice today

Media Tip #1

You can watch this series to see some realistic ways a kill chain might look like.
(IMDb Score: 8.5)



By Lockheed Martin, <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>

Potential Damages

- ▶ If a kill chain is successfully exploited, the consequence can be a great variety of damages, e.g.,
 - ▶ **Financial:** Direct (stolen credit card details, etc.) or indirect (loss of revenue due to bad publicity)
 - ▶ **Social:** Family or friends might fall also victim to attacker (use of messaging platforms, etc.), reputation might be damaged (loss of trust, etc.), etc.
 - ▶ **Legal:** Fines for data protection violations (GDPR), compensation for damages to third-parties (third-party has confidential data exposed, etc.), etc.
 - ▶ **Blackmail:** Attacker asks for certain action to be done (delete valuable data to company, etc.), asks for certain info to be send (trade secrets, etc.), etc.
 - ▶ **Livelihood:** Endangerment of lives by attacks on critical infrastructure, etc.
 - ▶ ...

Potential Damages

- ▶ So how can we prevent all these damages? 🤔
 - > Make sure we consider all relevant protection goals and that all our assumptions are mapped out and hold. 😎
- ▶ OK 😞 but then how do we make sure that we consider all relevant protection goals and that all our assumptions are mapped out and hold?
 - > We perform Risk & Threat Analyses. 😎

Learning Goal 3641DC

How to perform Risk & Threat Analyses?

What is Risk?

- ▶ Definition of risk by the International Organization for Standardization

Effect of uncertainty on objectives.

- ISO Guide 73:2009

- ▶ Useful to get a basic understanding...
- ▶ ...but leaves much room for interpretation
- ▶ What we actually want is a mathematical model

What is Risk?

- ▶ Risk matrices provide an abstract mathematical model
- ▶ Risk R_a of an attack a is the product

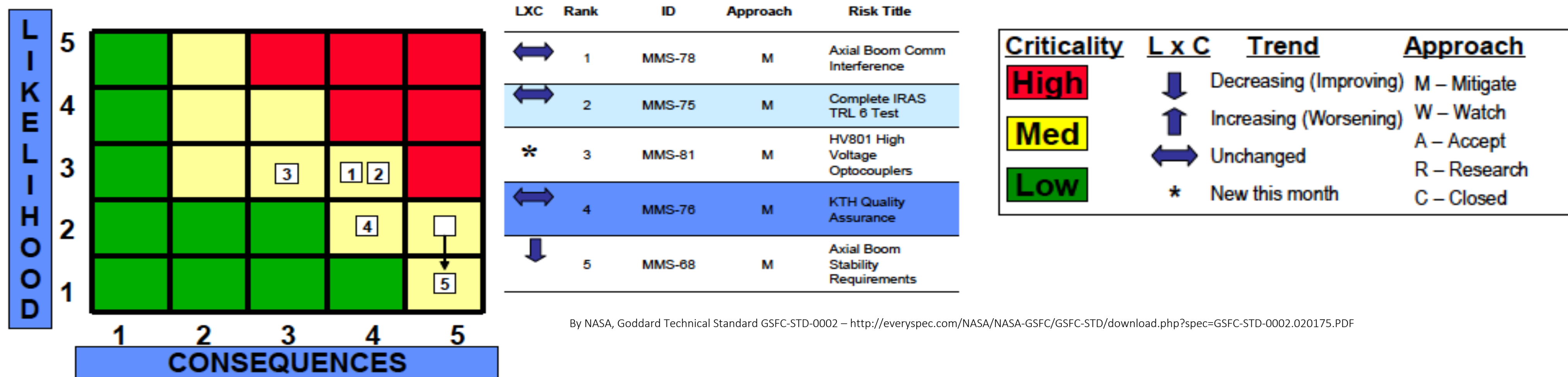
$$R_a = p_a * d_a$$

where p_a is the probability of attack a succeeding and d_a is the damage incurred by that attack if successful

- ▶ We already discussed damage, mostly expressed as cost in business
- ▶ But what about the probability?

What is Risk?

- Risk matrices use very coarse probabilities and can serve as a start



By NASA, Goddard Technical Standard GSFC-STD-0002 – <http://everyspec.com/NASA/NASA-GSFC/GSFC-STD/download.php?spec=GSFC-STD-0002.020175.PDF>

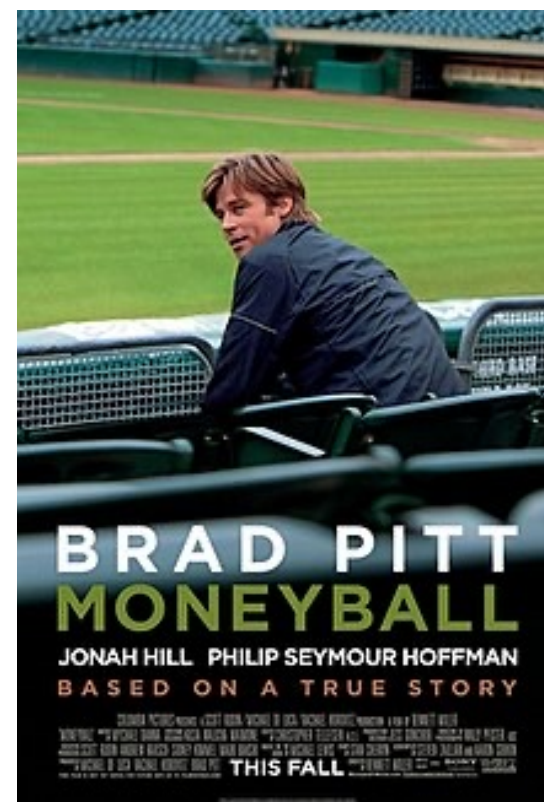
- It has been suggested that this might not be reliable enough in cybersecurity (& elsewhere)

What is Risk?

- ▶ Risk matrices use very coarse probabilities and can serve as a start
- ▶ It has been suggested that this might not be reliable enough in cybersecurity (& elsewhere)

- ▶ There are common misconceptions about these coarse estimates

- ▶ Cybersecurity cannot be measured but experts have a reliable intuition about it



Media Tip #2

You can watch this movie to learn about this topic (IMDb Score 7.6)

Our thesis is that people have strong intuitions about random sampling...these intuitions are wrong in fundamental respects...[and] are shared by naive subjects and by trained scientists.

- Amos Tversky & Daniel Kahneman

Overconfident professionals sincerely believe they have expertise, act as experts and look like experts. You will have to struggle to remind yourself that they may be in the grip of an illusion.

- Daniel Kahneman

This guy won the Nobel price

What is Risk?

- ▶ Risk matrices use very coarse probabilities and can serve as a start
- ▶ It has been suggested that this might not be reliable enough in cybersecurity (& elsewhere)
- ▶ There are common misconceptions about these coarse estimates
 - ▶ Cybersecurity cannot be measured but experts have a reliable intuition about it
 - ▶ Expert estimates are consistent



21% of variation in expert responses are explained by inconsistency.
(79% are explained by the actual information they were given)

What is Risk?

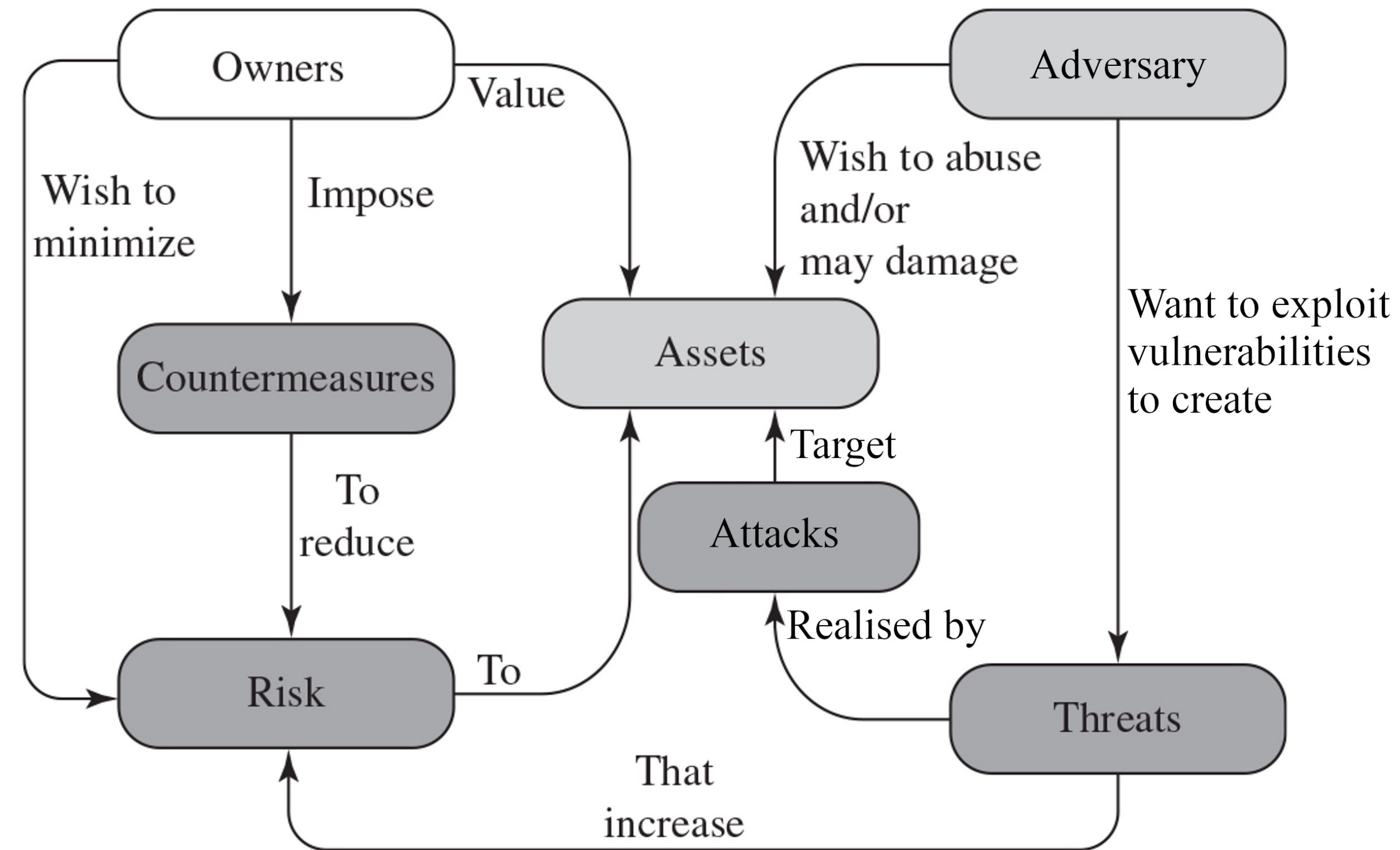
- ▶ Risk matrices use very coarse probabilities and can serve as a start
- ▶ It has been suggested that this might not be reliable enough in cybersecurity (& elsewhere)
- ▶ There are common misconceptions about these coarse estimates
 - ▶ Cybersecurity cannot be measured but experts have a reliable intuition about it
 - ▶ Expert estimates are consistent
- ▶ So please use as exact probability estimates as possible, based on actual data even if it is sparse

What are Threats?

To discuss this, we need to look at a few other terms as well

- ▶ **Asset:** Any “thing” that holds value, cf. definition on slide 11 for examples.
- ▶ **Adversary:** Any entities (individual, group, organization, or government) that conducts or has the intent to conduct malicious activities.
- ▶ **Vulnerability:** A weakness in an information system, system security procedures, internal controls, or implementation that could be exploited or triggered by an adversary.
- ▶ **Threat:** Any circumstance or event with the potential to adversely impact an asset via exploiting a vulnerability.
- ▶ **Attack:** Any kind of malicious activity that realises a threat targetting an asset.
- ▶ **Countermeasure:** Any device or techniques that has as its objective the impairment of the operational effectiveness of attacks.

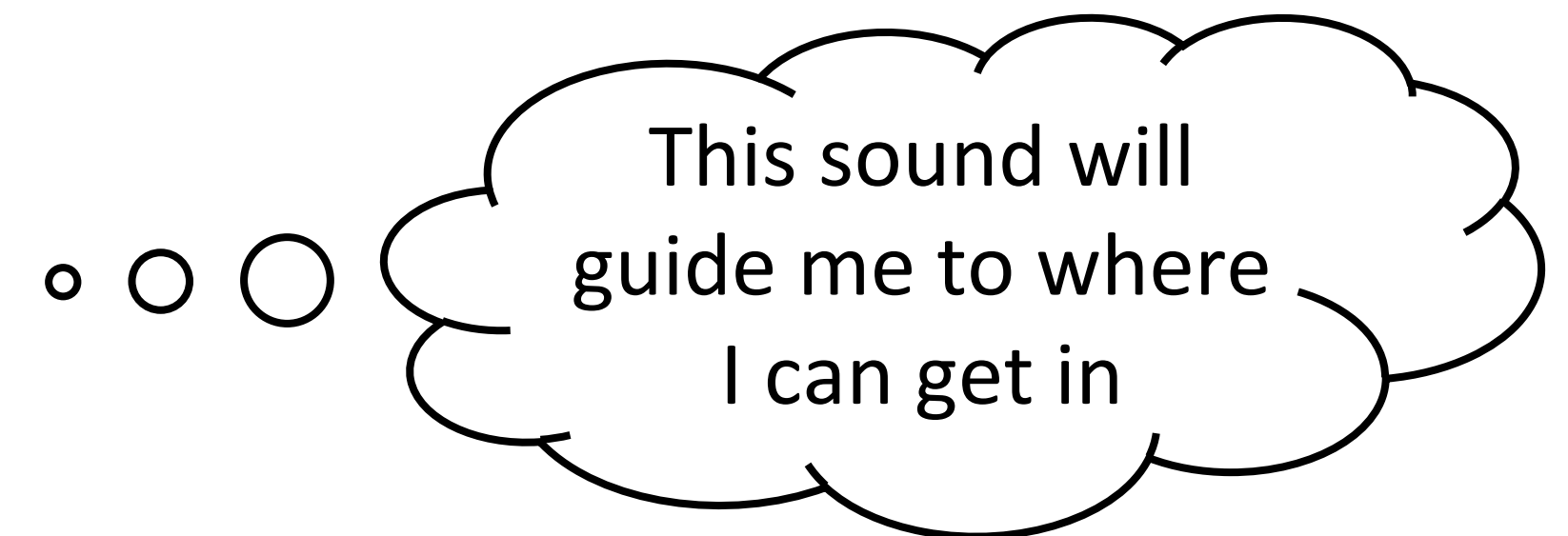
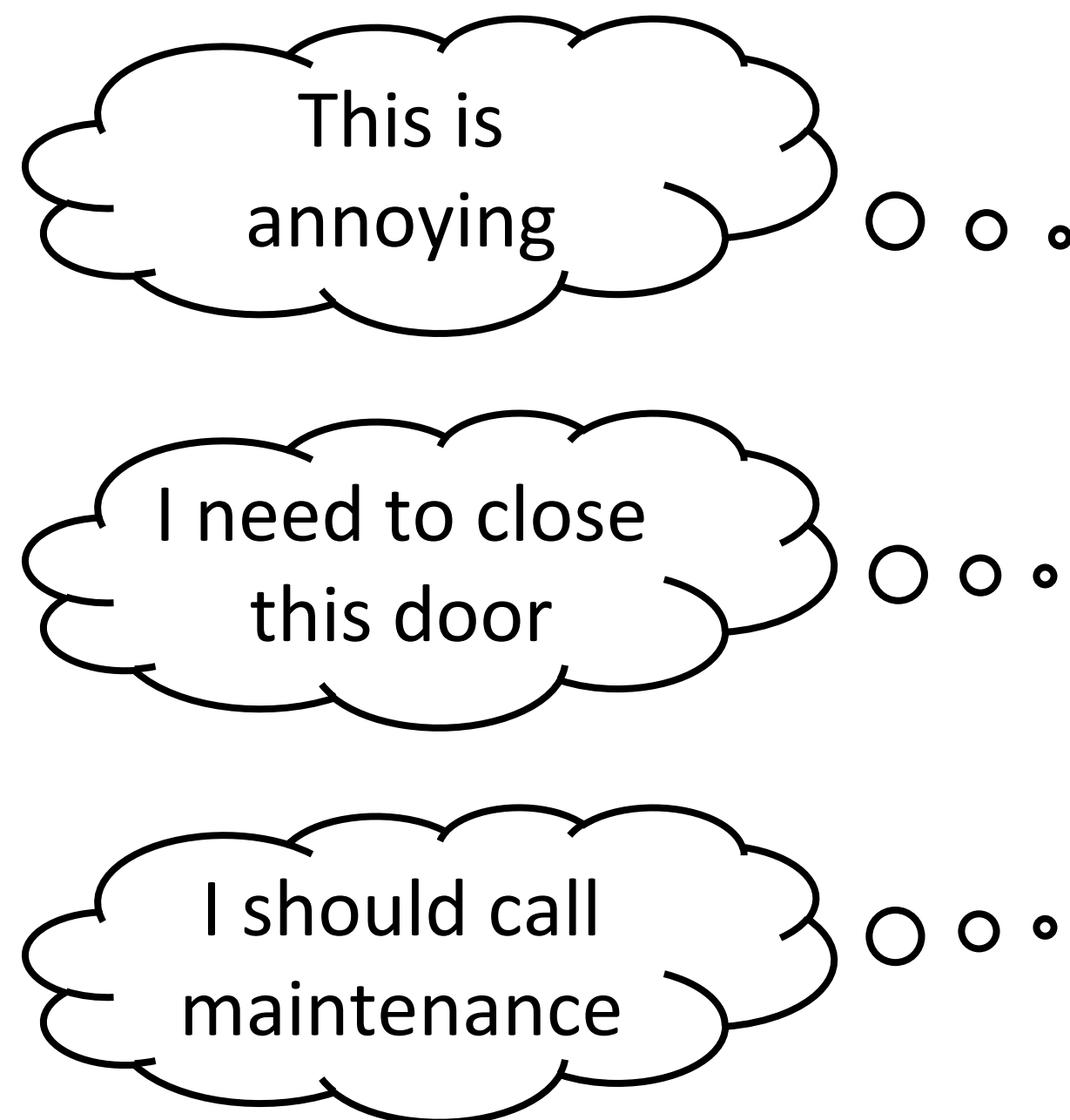
Putting it all together



Adapted from William Stallings & Lawrie Brown, Computer Security: Principles and Practice

Security Mindset

- ▶ Security experts need a specific mindset
 - ▶ Which parts of this do users have control over? Which ones shouldn't they?
 - ▶ What can this do outside of what it is meant to do?
 - ▶ Is any of that unintended functionality useful?



Security Mindset

- ▶ Security experts need a specific mindset
 - ▶ Which parts of this do users have control over? Which ones shouldn't they?
 - ▶ What can this do outside of what it is meant to do?
 - ▶ Is any of that unintended functionality useful?
- ▶ Example from the blog of Bruce Schneier (security guru™)

Uncle Milton Industries has been selling ant farms to children since 1956. Some years ago, I remember opening one up with a friend. There were no actual ants included in the box. Instead, there was a card that you filled in with your address, and the company would mail you some ants. My friend expressed surprise that you could get ants sent to you in the mail.

I replied: "What's really interesting is that these people will send a tube of live ants to anyone you tell them to."

Security Mindset

► Another example: “SmartWater Forensic Liquid”



Incidents of theft and burglary at business premises have seen an increase in the last few years, usually creating significant disruption to the operation of the business targeted. DeterTech's range of SmartTrace® products protect business assets and infrastructure, providing a simple and effective means for protecting your business from thieves.

- Contains a unique forensic code
- Makes assets traceable back to the business
- Easy to apply
- Near invisible to the naked eye
- Near impossible to remove
- Glows SmartWater's trademarked bright yellow-green under UV light
- Guaranteed for a minimum of 5-years once applied

- Which parts of this do users have control over but shouldn't?
- What can this do outside of what it is meant to do?
- Is any of that unintended functionality useful?

What do you think?

Security requires economic decision making

- ▶ Back to the antfarm example
 - ▶ The problem is the authenticity of the ant request
 - ▶ What can be done about it?
 - ▶ Add a one-use serial number that is disabled when the request is fulfilled
 - ▶ Add a watermark/hologram to the card that makes it hard to forge
 - ▶ Ask people to attach the proof of purchase (e.g., receipt)
 - ▶ ...
- ▶ Do the ant request cards need to be as resistant to forgery as money?
 - > That is an economic decision

Security requires economic decision making

- ▶ Security is about preventing losses
- ▶ A countermeasure makes sense as long as the risk it mitigates is greater than its costs

$$L_{ca} = R_{ac} + C_c - R_{a\neg c}$$

- ▶ L_{ca} : Losses incurred (damages & costs of countermeasures)
- ▶ $R_{a\neg c}$: Risk in case attack a without countermeasure c
- ▶ R_{ac} : Risk in case attack a with countermeasure c
- ▶ C_c : Cost of countermeasure c

Interlude: Should safety be based on economics as well?

Business / Tech

‘It’s putting patients’ lives in danger’: Nurses say ransomware attack is stressing hospital operations



By [Sean Lyngaas](#), CNN

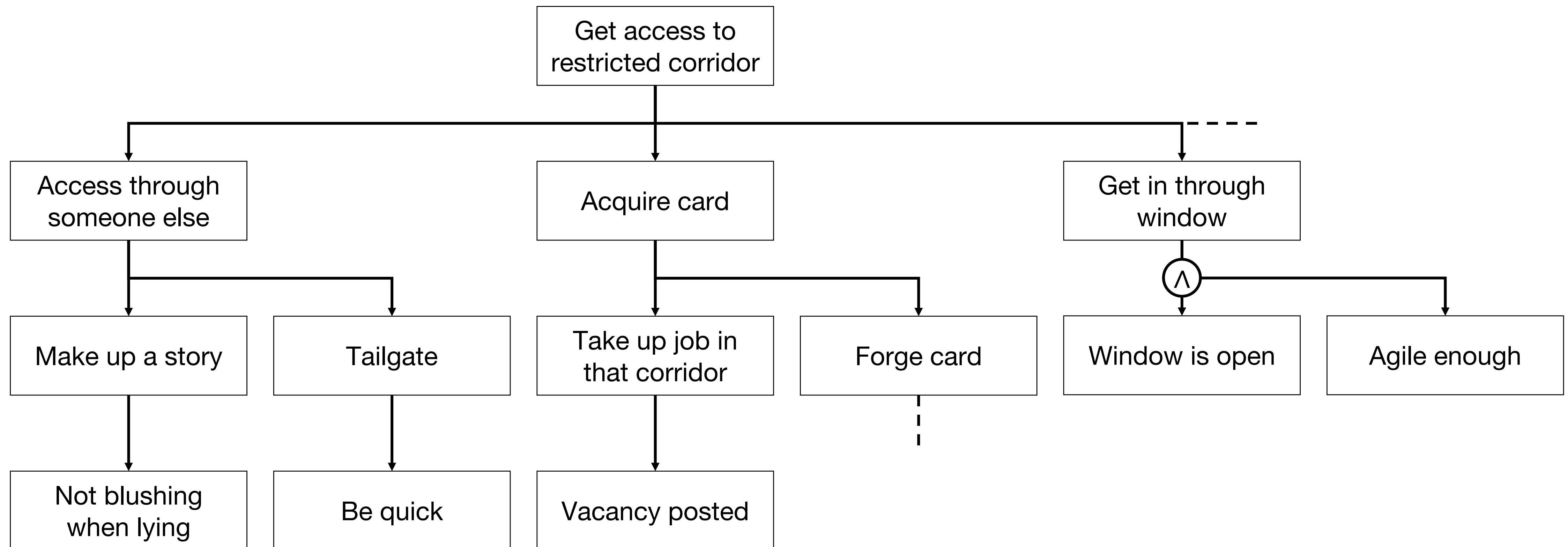
🕒 6 minute read · Published 12:16 PM EDT, Wed May 29, 2024



► What if a security threat leads to a safety issue?

Attack Trees

- ▶ Attack trees allow mapping out risks systematically
- ▶ Can create intuitive graphical overviews, when properly documented



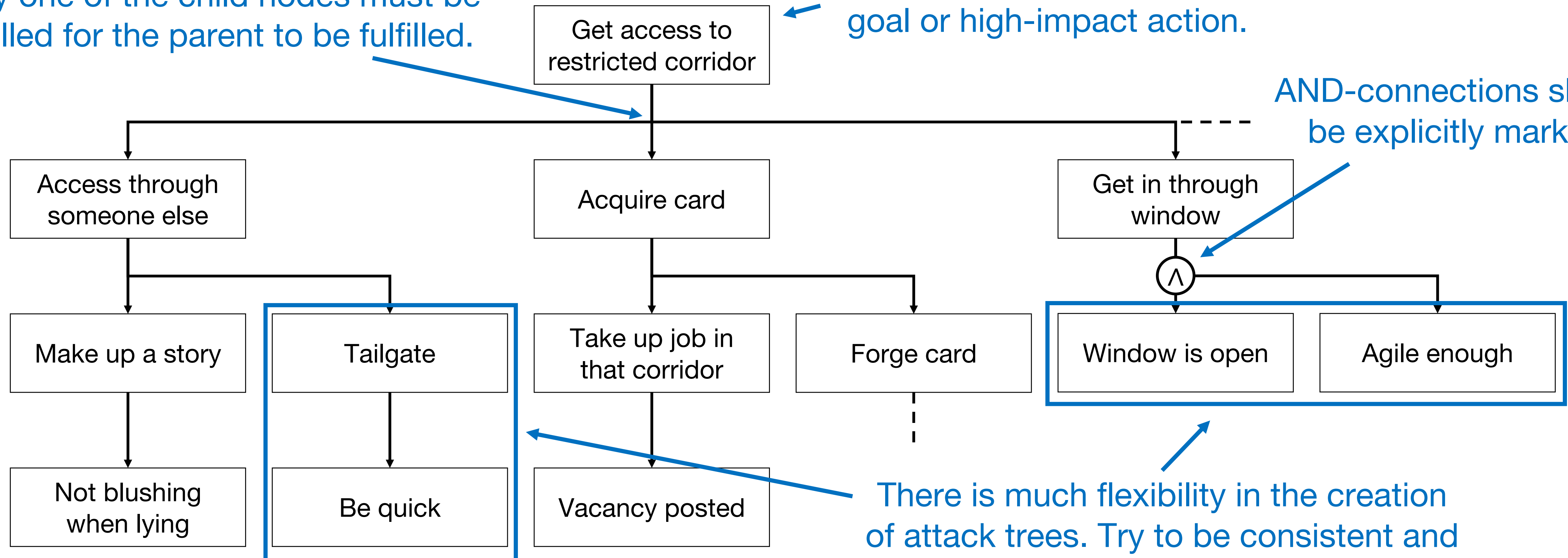
Attack Trees – Create the tree

Use a grid structure to arrange the nodes.
This makes the tree easier to read.

Nodes are usually OR-connected.
Only one of the child nodes must be fulfilled for the parent to be fulfilled.

The root node is an attacker goal or high-impact action.

AND-connections should be explicitly marked.



There is much flexibility in the creation of attack trees. Try to be consistent and deliberate in your modelling. When in doubt document what things mean.

Attack Trees – Create the tree

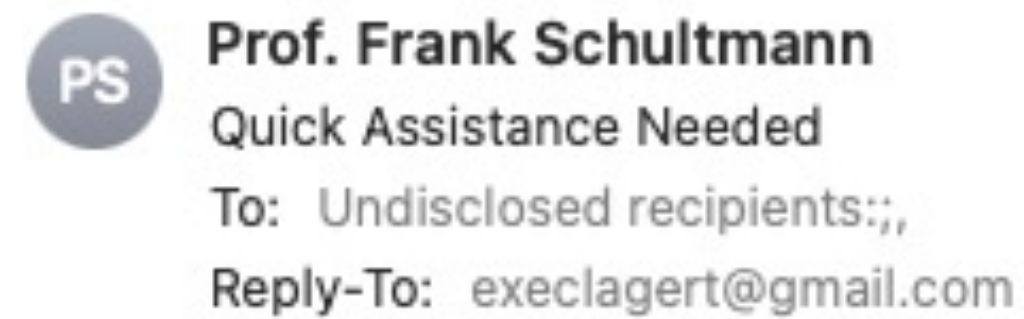
- ▶ How to find the nodes?
 - ▶ Brainstorming, best done in a team
 - ▶ Think of the relevant protection goals
 - ▶ Consult frameworks of attack terminology, e.g.,
 - ▶ Kill chain
 - ▶ STRIDE
 - ▶ MITRE ATT&CK
- ▶ Consider even unlikely attacks at this step

STRIDE

- ▶ Taxonomy for attack types
- ▶ Spoofing: Pretending to be someone/something you are not
- ▶ Tampering: Modify something you are not meant to modify
- ▶ Repudiation: Claim you didn't do sth. (regardless of whether you did it)
- ▶ Information Disclosure: Information is exposed to unauthorised people
- ▶ Denial of Service: Attacks designed to prevent providing a service, e.g., by making it slow
- ▶ Elevation of Privilege: A user is able to do things in a system they are not supposed to do

STRIDE - Examples

Spoofing



Falsified Sender

Tampering

```
sha256sum --check checksum
file1: FAILED
sha256sum: WARNING: 1 computed checksum did NOT match
```

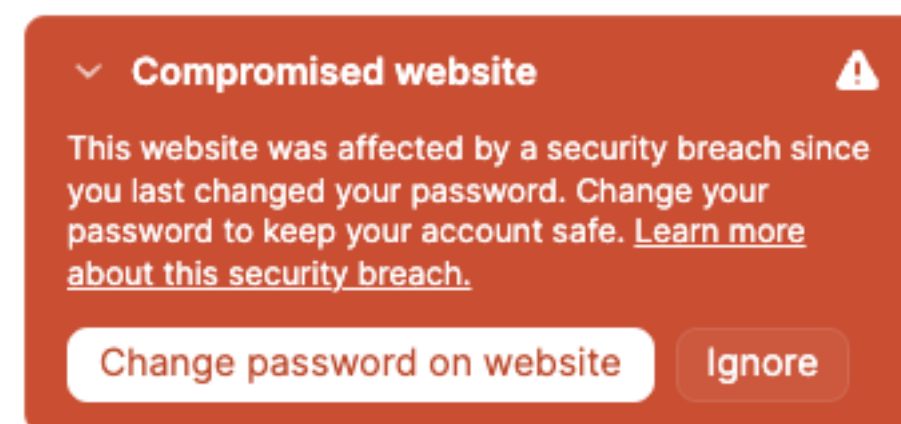
Manipulated Files

Repudiation



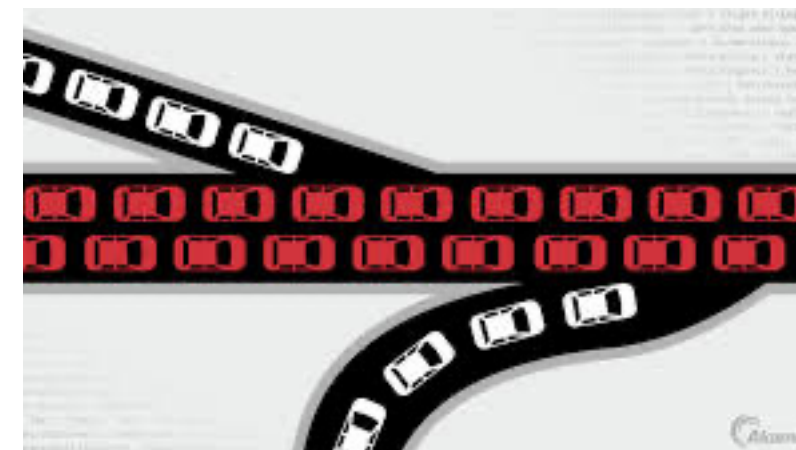
Deny Having Taken Actions

Information Disclosure



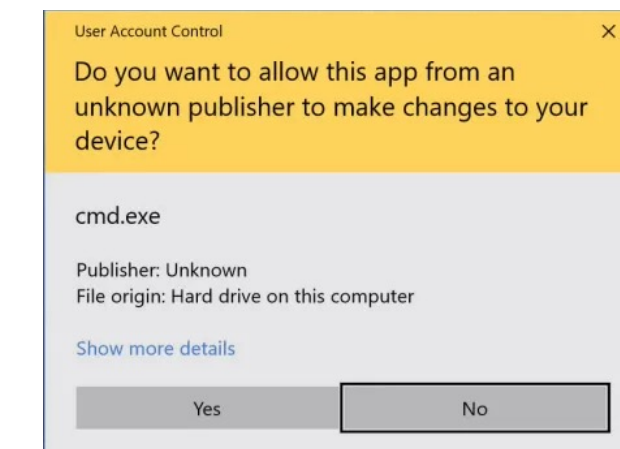
Data Breaches

Denial of Service



Saturation of Network Link

Elevation of Privilege



Run as Privileged User

MITRE ATT&CK

- ▶ Adversarial Tactics, Techniques, and Common Knowledge
- ▶ Framework to document attack behaviour
- ▶ Establishes common taxonomy for attacks
- ▶ Models adversary behaviours

- ▶ Is in essence a knowledge base of adversarial techniques
- ▶ Techniques are sorted into categories
- ▶ Techniques can have sub-techniques

- ▶ Freely available online: <https://attack.mitre.org/tactics/TA0043/>

What is Cybersecurity?

MITRE ATT&CK

Reconnaissance 10 techniques	Resource Development 8 techniques	Initial Access 10 techniques	Execution 14 techniques	Persistence 20 techniques	Privilege Escalation 14 techniques	Defense Evasion 43 techniques	Credential Access 17 techniques	Discovery 32 techniques	Lateral Movement 9 techniques	Collection 17 techniques	Command and Control 18 techniques	Exfiltration 9 techniques	Impact 14 techniques
Active Scanning (3)	Acquire Access	Content Injection	Cloud Administration Command	Account Manipulation (6)	Abuse Elevation Control Mechanism (6)	Abuse Elevation Control Mechanism (6)	Adversary-in-the-Middle (3)	Account Discovery (4)	Exploitation of Remote Services	Adversary-in-the-Middle (3)	Application Layer Protocol (4)	Automated Exfiltration (1)	Account Access Removal
Gather Victim Host Information (4)	Acquire Infrastructure (8)	Drive-by Compromise	Command and Scripting Interpreter (10)	BITS Jobs	Access Token Manipulation (5)	Access Token Manipulation (5)	Brute Force (4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (3)	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction
Gather Victim Identity Information (3)	Compromise Accounts (3)	Exploit Public-Facing Application	Container Administration Command	Boot or Logon Autostart Execution (14)	Account Manipulation (6)	Account Manipulation (5)	Credentials from Password Stores (6)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Content Injection	Exfiltration Over Alternative Protocol (3)	Data Encrypted for Impact
Gather Victim Network Information (6)	Compromise Infrastructure (8)	External Remote Services	Deploy Container	Boot or Logon Initialization Scripts (5)	Boot or Logon Autostart Execution (14)	BITS Jobs	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (2)	Automated Collection	Data Encoding (2)	Exfiltration Over C2 Channel	Data Manipulation (3)
Gather Victim Org Information (4)	Develop Capabilities (4)	Hardware Additions	Exploitation for Client Execution	Browser Extensions	Boot or Logon Initialization Scripts (5)	Debugger Evasion	Forced Authentication	Cloud Service Dashboard	Remote Services (8)	Browser Session Hijacking	Data Obfuscation (3)	Exfiltration Over Other Network Medium (1)	Defacement (2)
Phishing for Information (4)	Establish Accounts (3)	Phishing (4)	Inter-Process Communication (3)	Compromise Host Software Binary	Boot or Logon Initialization Scripts (5)	Deobfuscate/Decode Files or Information	Forge Web Credentials (2)	Cloud Service Discovery	Replication Through Removable Media	Clipboard Data	Dynamic Resolution (3)	Exfiltration Over Physical Medium (1)	Disk Wipe (2)
Search Closed Sources (2)	Obtain Capabilities (7)	Replication Through Removable Media	Native API	Create Account (3)	Create or Modify System Process (5)	Deploy Container	Input Capture (4)	Cloud Storage Object Discovery	Software Deployment Tools	Data from Cloud Storage	Encrypted Channel (2)	Exfiltration Over Web Service (4)	Endpoint Denial of Service (4)
Search Open Technical Databases (5)	Stage Capabilities (6)	Supply Chain Compromise (3)	Scheduled Task/Job (5)	Event Triggered Execution (16)	Escape to Host	Direct Volume Access	Modify Authentication Process (9)	Container and Resource Discovery	Taint Shared Content	Data from Configuration Repository (2)	Fallback Channels	Transfer Data to Cloud Account	Financial Theft
Search Open Websites/Domains (3)		Trusted Relationship	Serverless Execution	External Remote Services	Event Triggered Execution (16)	Domain or Tenant Policy Modification (2)	Multi-Factor Authentication Interception	Debugger Evasion	Use Alternate Authentication Material (4)	Data from Information Repositories (3)	Hide Infrastructure		Firmware Corruption
Search Victim-Owned Websites		Valid Accounts (4)	Shared Modules	Hijack Execution Flow (13)	Exploitation for Privilege Escalation	Execution Guardrails (1)	Multi-Factor Authentication Request Generation	Device Driver Discovery		Data from Local System	Ingress Tool Transfer		Inhibit System Recovery
			Software Deployment Tools	Implant Internal Image	Hijack Execution Flow (13)	Exploitation for Defense Evasion	Network Sniffing	Domain Trust Discovery		Data from Network Shared Drive	Multi-Stage Channels		Resource Hijacking
			System Services (2)	Modify Authentication Process (9)	Process Injection (12)	File and Directory Permissions Modification (2)	OS Credential Dumping (8)	File and Directory Discovery		Data from Removable Media	Non-Application Layer Protocol		Service Stop
			User Execution (3)	Office Application Startup (6)	Scheduled Task/Job (5)	Hide Artifacts (12)	Steal Application Access Token	Log Enumeration		Data Staged (2)	Non-Standard Port		System Shutdown/Reboot
			Windows Management Instrumentation	Power Settings	Valid Accounts (4)	Hijack Execution Flow (13)	Steal or Forge Authentication Certificates	Network Service Discovery		Email Collection (3)	Protocol Tunneling		
				Pre-OS Boot (5)		Impair Defenses (11)	Steal or Forge Kerberos Tickets (4)	Network Share Discovery		Input Capture (4)	Proxy (4)		
				Scheduled Task/Job (5)		Impersonation	Unsecured Credentials (6)	Network Sniffing		Screen Capture	Remote Access Software		
				Server Software Component (5)		Indicator Removal (9)		Password Policy Discovery		Video Capture	Traffic Signaling (2)		
				Traffic Signaling (2)		Indirect Command Execution		Peripheral Device Discovery			Web Service (3)		
				Valid Accounts (4)		Masquerading (9)		Permission Groups Discovery (3)					
						Modify Authentication Process (9)		Process Discovery					
						Modify Cloud Compute Infrastructure (5)		Query Registry					
						Modify Registry		Remote System Discovery					
						Modify System Image (2)		Software Discovery (1)					
						Network Boundary Bridging (1)		System Information Discovery					
						Obfuscated Files or Information (13)		System Location Discovery (1)					
						Plist File Modification		System Network Configuration Discovery (2)					
						Pre-OS Boot (5)		System Network Connections Discovery					
						Process Injection (12)		System Owner/User Discovery					
						Reflective Code Loading		System Service Discovery					
						Rogue Domain Controller		System Time Discovery					
						Rootkit		Virtualization/Sandbox Evasion (3)					
						Subvert Trust Controls (6)							
						System Binary Proxy Execution (14)							
						System Script Proxy Execution (2)							
						Template Injection							
						Traffic Signaling (2)							
						Trusted Developer Utilities Proxy Execution (1)							
						Unused/Unsupported Cloud Regions							
						Use Alternate Authentication Material (4)							
						Valid Accounts (4)							
						Virtualization/Sandbox Evasion (3)							
						Weaken Encryption (2)							
						XSL Script Processing							

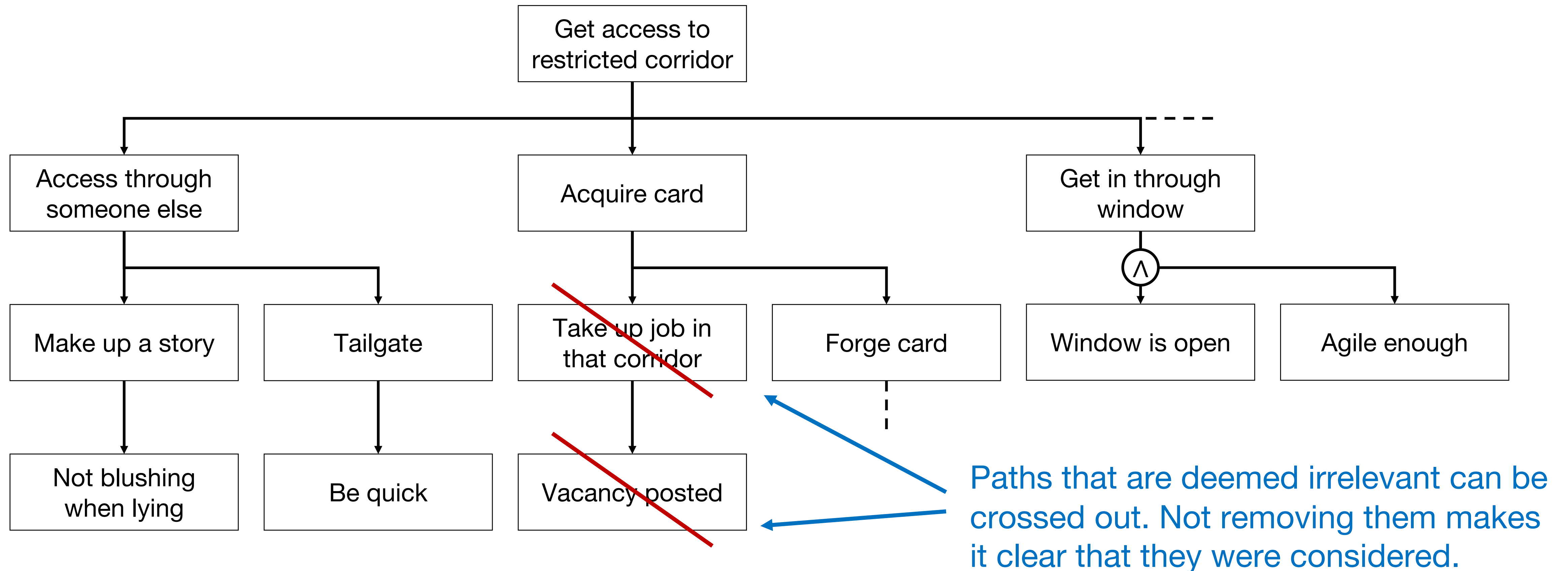
MITRE ATT&CK

Reconnaissance

10 techniques

Active Scanning (3)	
Gather Victim Host Information (4)	
Gather Victim Identity Information (3)	
Gather Victim Network Information (6)	
Gather Victim Org Information (4)	
Phishing for Information (4)	
Search Closed Sources (2)	
Search Open Technical Databases (5)	
Search Open Websites/Domains (3)	
Search Victim-Owned Websites	

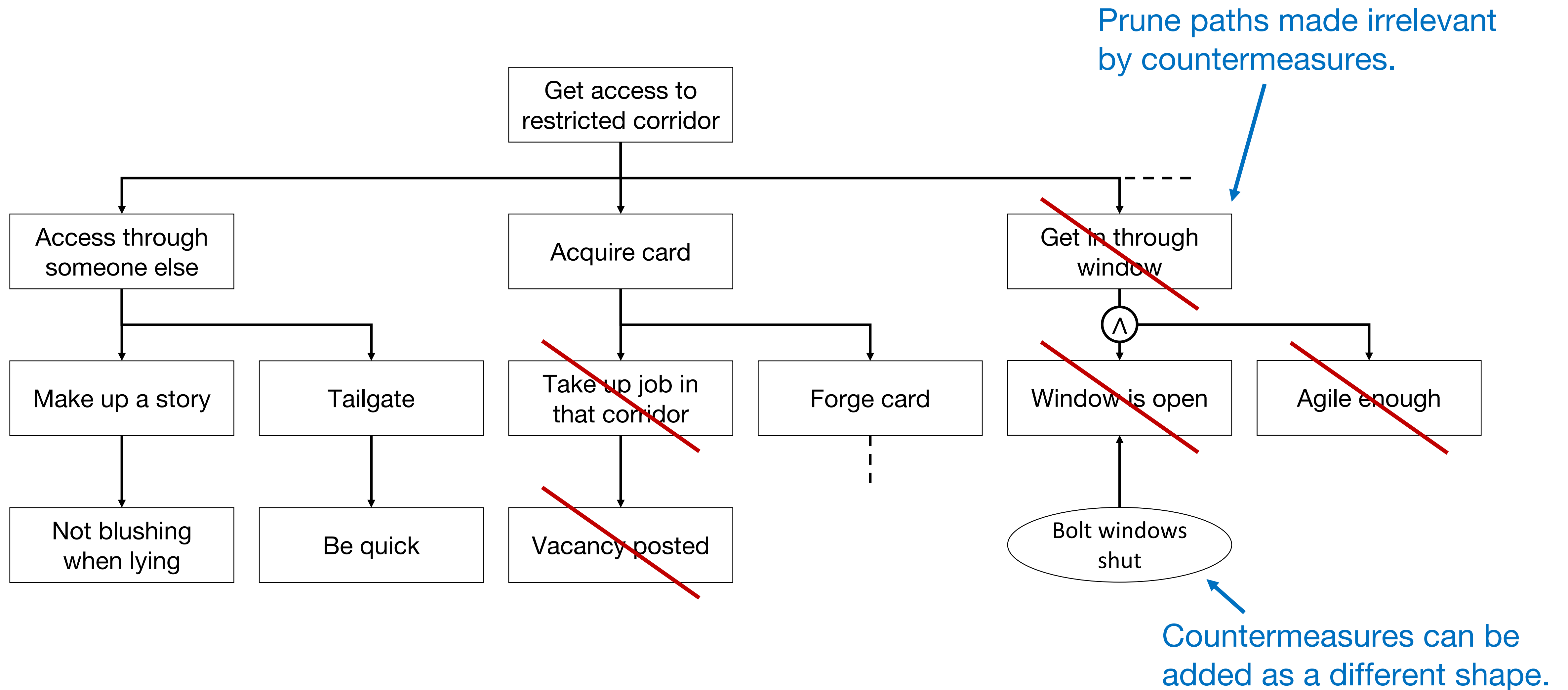
Attack Trees – Prune the tree



Attack Trees – Prune the tree

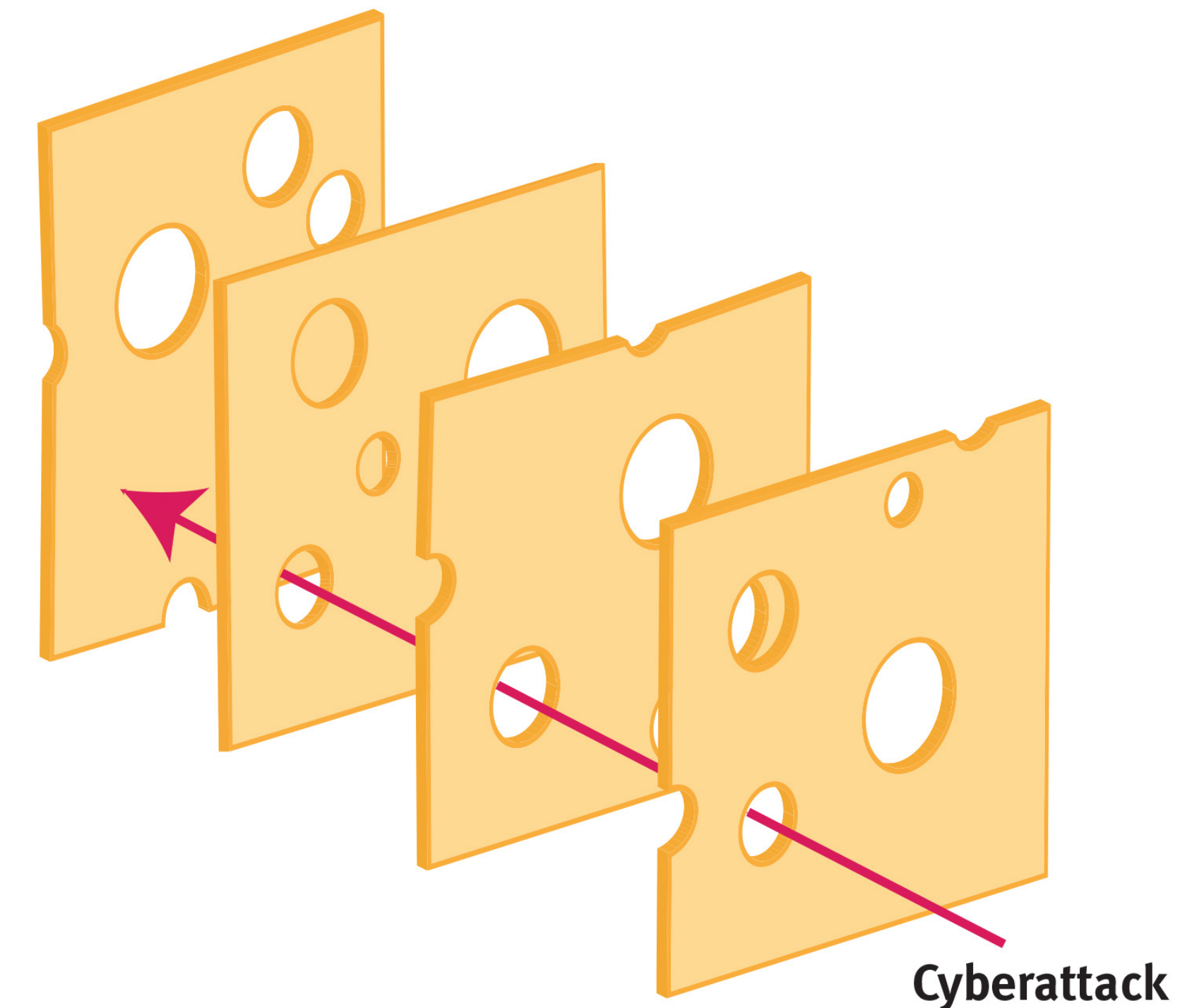
- ▶ Identify paths that are not possible
- ▶ Relevant are
 - ▶ Circumstances that do not allow a path to succeed (not considering countermeasures)
 - ▶ Risk posed by different types of adversaries
 - ▶ Adversary classification
 - ▶ Black Hat Hackers: Act with criminal intent
 - ▶ White Hat Hackers: Hired by companies to test security
 - ▶ Grey Hat Hackers: Do not act with malicious intent, but are not hired
 - ▶ Threat
 - ▶ Joy hacks
 - ▶ Opportunistic attacks
 - ▶ Targeted attacks
 - ▶ Advanced persistent threats

Attack Trees – Think about countermeasures



Attack Trees – Think about countermeasures

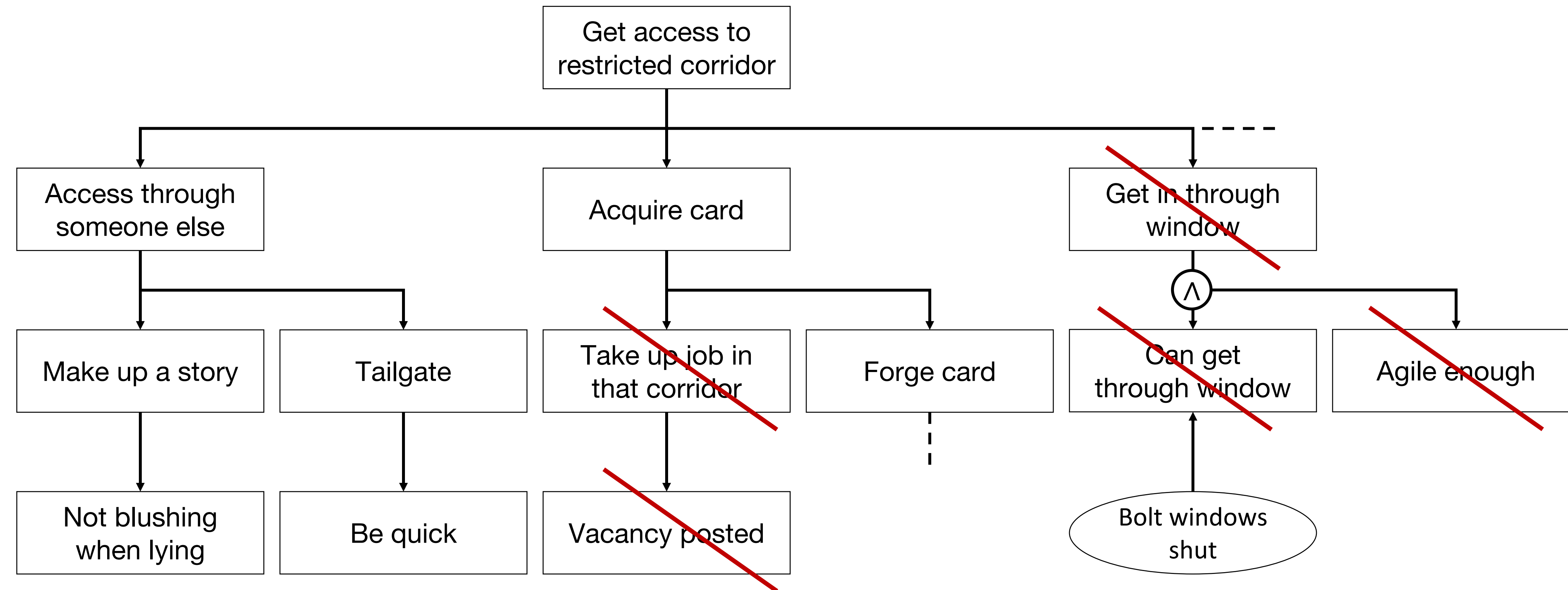
- ▶ Is one countermeasure enough?
- ▶ Technically yes, but actually no
- ▶ Swiss Cheese Model of Cybersecurity
- ▶ If one countermeasure fails, we want another one to fend off adversaries
- ▶ The attacker will only get through if all countermeasures fail



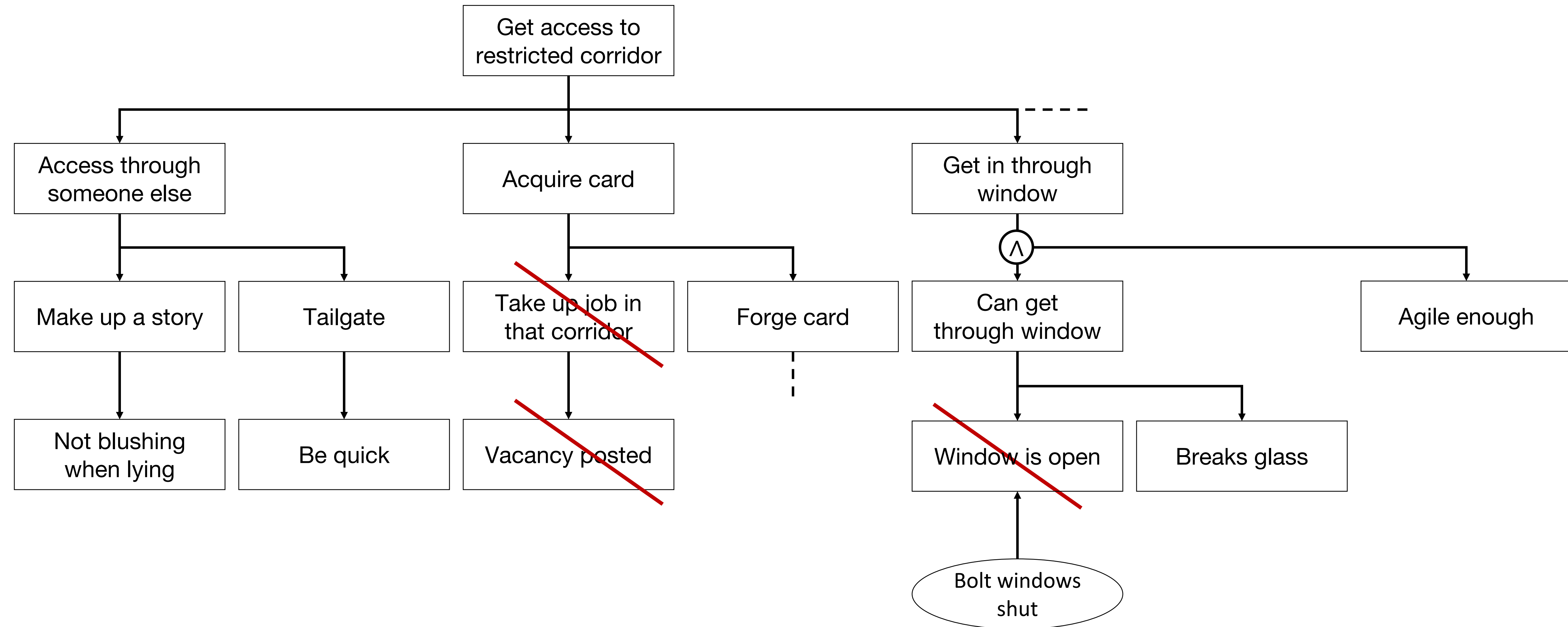
<https://www.eenewseurope.com/en/the-swiss-cheese-approach-to-automotive-security-2/>

- ▶ This is called **Layered Security** or **Defense in Depth**

Attack Trees – Think about countermeasures



Attack Trees – Think about countermeasures



Attack Trees – Alternative Textual Notation

Hierarchical list to
describe tree
structure

- Get access to restricted corridor
 - 1. Access through someone else
 - 1.1. Make up a story
 - 1.1.1. Not blushing when lying
 - 1.2. Tailgate
 - 1.2.1. Be quick
 - 2. Acquire card
 - 2.1. Take up job in that corridor
 - 2.1.1. Vacancy posted
 - 2.2. Forge card
 - 2.2.1. ...
 - 3. Get in through window
 - 3.1. Can get through window
 - 3.1.1. Agile enough
 - 3.1.1.1. Window is open
 - Bolt windows shut
 - 3.1.1.2. Break glass
 - 4. ...

Ambiguity resolved
through clear
hierarchy of elements

Countermeasure
specifically marked

Learning Goals

- ▶ Get an understanding of what cybersecurity is ✓
 - ▶ Definitions of cybersecurity
 - ▶ The difference between security and safety
 - ▶ Security goals and their role in cybersecurity
 - ▶ Assumptions and their role in cybersecurity
 - ▶ The cybersecurity killchain
- ▶ Understand how to perform risk and threat analyses ✓
 - ▶ The security mindset
 - ▶ Risk & threat analyses based on attack trees
 - ▶ The STRIDE classification of threats
 - ▶ Attacker motivations